

Policy Owner	Effective Date	Version	Next Review Date
IT Director / HIPAA Security Officer	June 14, 2026	1.0	June 14, 2027

PURPOSE:

The purpose of this policy is to ensure damage is minimized from security incidents, as well as that PHI is protected and for HIPAA breach notification obligations to be met. There is also a focus of normal operations being restored as quickly as possible with evidence being preserved for legal or regulatory purposes. The final focus will be to ensure that incidents are learned from to prevent recurrence.

SCOPE:

This policy applies to all employees across all three primary departments. It applies as well to any contractors, third-party vendors, or persons with system access. This will include everyone on company owned devices and on the network of the clinic.

ROLES & RESPONSIBILITIES:

1. IT Director / HIPAA Security Officer - Owner of the policy, final decision maker during active incidents, responsible for HIPAA breach notifications and annual policy review
2. IT Team - First responders to all reported incidents. Responsible for detection, containment, eradication, recovery, and post-incident documentation.
3. Department Managers - Responsible for ensuring their staff are trained on incident recognition and reporting procedures. Must be notified by IT during Severity 1 and 2 incidents affecting their department
4. Employees - Responsible for immediately reporting any suspicious activity on their devices or the network to the IT team. Must not attempt to investigate or resolve suspected incidents themselves.
5. Chief Medical Officer(CMO) - Must be notified immediately during Severity 1 incidents involving confirmed or suspected PHI exposure. Responsible for patient communication decisions during breach scenarios.

POLICY STATEMENTS:

1.1 The policy maps to NIST SP 800-61 four phases of an incident response lifecycle, the four phases are to be found in the APPENDIX below

1.2 The policy also has four tiers of classification for incidents for responders to know how urgent the situation is, it is also found in the APPENDIX below

1.3 A report must be made to HHS Office for Civil Rights within 60 days for breaches affecting 500 or more individuals, smaller breaches may be reported annually.

1.4 The local media must be notified within 60 days if a breach affects 500 or more residents of a state or jurisdiction

1.5 Individual notifications must be sent out to patients affected by any breach within 60 days of discovery

1.6 Employees must immediately report any suspicious activity on the network, their devices, or on any technological resource of the organization to the IT team.

1.7 Upon receipt of a report from an employee the IT team must immediately categorize the incident into a tier and act accordingly to what the tier requires and follow the four-phase response plan.

COMPLIANCE & ENFORCEMENT:

Failure to ensure compliance with the IRP, which includes failure to report incidents, unauthorized handling of incidents outside of this policy, and/or failure to meet HIPAA breach notification timelines may result in disciplinary action up to and including termination of employment. The violations of HIPAA which involve PHI may result in civil and criminal penalties that the U.S Department of Health and Human Services Office for Civil Rights enforces. Fines can range from \$100 to \$50,000 per violation which is dependent on the negligence level.

EXCEPTIONS:

Exceptions to the standard IRP may have authorization only given by the IT Director in real-time during an ongoing incident where a strict adherence to the plan would cause greater harm than deviating from it. All exceptions to the plan must be documented in the post-incident report.

REVIEW CYCLE:

This policy will be reviewed annually or after any significant security incident.

APPENDIX A - NIST SP 800-61 Incident Response Phases:

Phase 1 - Preparation: Everything that happens before an incident. Ensuring staff is trained to recognize and report suspicious activity, maintaining contact lists, keeping an offboarding checklist, having systems patched and logged. Ensuring employees know to report to IT immediately.

Phase 2 - Detection & Analysis: An employee reports something. IT can receive the report and begin to determine whether it's an incident or non malicious technical bug. They classify severity, check logs, and determine what type of incident it is.

Phase 3 - Containment, Eradication and Recovery: Ensuring the machine is isolated from the network immediately upon report. Then an investigation of lateral movement and privilege escalation. Afterwards the malware is removed and the vulnerability is closed. Then restore from a clean backup, verify the system is safe and return to operation.

Phase 4 - Post Incident Activity: A documentation by the IT team of what happened, how it was handled, what worked and what didn't and an update to the IRP accordingly. There will also be a formal breach assessment conducted and reported to HHS within 60 days if PHI was accessed or exposed.

APPENDIX B - Incident Severity Classification Table:

SEVERITY 1(CRITICAL) - Active breach or confirmed unauthorized access to PHI, ransomware encrypting systems, an outage of the complete EHR system. This requires immediate response and for the IT Director & CMO to be notified within 1 hour. Potential HIPAA breach notification is triggered as well.

SEVERITY 2(HIGH) - A suspicion of unauthorized access, detection of malware but no confirmation of it having spread, a single system compromise with no exposure of PHI confirmed. The IT director will be notified within 4 hours with an immediate investigation to begin.

SEVERITY 3(MEDIUM) - A violation of policy without a confirmation of exposed data, a phishing email reported before being clicked, flagging suspicious network activity from monitoring. There will be an investigation done by the IT team within 24 hours with the IT director being notified the same day.

SEVERITY 4(LOW) - Violations of policy which are minor, login attempts failing in normal thresholds, staff making general security awareness reports. This is logged and reviewed during regular IT review cycles.

APPENDIX C - Incident Response Checklist:

Upon receipt of an incident report:

- The incident must have its severity classified according to the table in Appendix B
- The IT Director must immediately be notified for Severity 1 or 2
- The CMO must be immediately notified if there is any suspected or confirmed exposure of PHI
- The affected system must be isolated from the network
- The system logs must be preserved and the affected devices must not be powered off
- There has to be documentation of the initial observations, the name of reporter, and time of report
- Containment procedures must begin per Phase 3 guidelines
- Once the incident is resolved, the post-incident report must be completed within 5 business days
- If there is any confirmation of PHI exposure then a HIPAA breach assessment must be initiated and HHS is notified within 60 days.

VERSION HISTORY TABLE:

Version	Date	Author	Description of Changes
1.0	6/14/2026	Bryan Alcivar	Initial Policy Creation